CYBERSECURITY INTERNSHIP PRACTICAL LAB REPORT

Day 06: Spear Phishing Email Craft, MIME Forensics & Email Authentication Defense

Engineering Security-Awareness Training Drafts, Header Spoofing Mechanics, and SPF/DKIM/DMARC Blueprints

INTERNSHIP TRACK: Social Engineering Attack Simulations	**DATE OF EXECUTION:** October 26, 2026
INTERN / RESEARCHER: Md Peer Siddiqui	**TARGET REPOSITORY:** PEER-S-Spear-Phish-Crafter
HOST ORGANIZATION: Sqrock IT Solution	**GITHUB:** github.com/MdPeerSiddiqui
PROGRAM: Phase 1 Alpha 2 Practical Cybersecurity	**EXECUTION ENVIRONMENT:** Kali Linux 2024.x & Win11

1. Executive Summary & Strategic Context

Unlike mass untargeted phishing, **Spear Phishing** represents a precision-guided social engineering methodology where threat actors weaponize Open-Source Intelligence (OSINT) gathered on specific high-value employees. By embedding verified personal details—such as the victim's name, corporate role, division, physical office location, and direct reporting structure—adversaries create pretexts with unprecedented psychological authority and credibility.

For **Day 06** of the Sqrock IT Solution Cybersecurity Internship, a production-grade Python security suite titled **PEER'S Spear Phish Crafter** was engineered. Operating strictly in an authorized laboratory environment, the tool generates three realistic security-awareness simulation drafts (Corporate IT, HR & Payroll, and Supply Chain Finance), analyzes RFC 5322 MIME header spoofing techniques, and establishes an authoritative **SPF, DKIM, and DMARC defender implementation guide** to immunize enterprise domains against inbound spoofing.

2. Scope of Investigation & Technical Objectives

Technical Objective	Methodology & Focus Area	Verification Deliverable
1. Personalized Awareness Drafts	Dynamic token replacement across 3 distinct enterprise attack vectors.	Exported drafts in spear_phish_templates.json.
2. RFC 5322 Header Forensics	Inspection of From, Reply-To, Return-Path, and X-Mailer headers.	MIME header visualizer embedded in CLI and PDF report.
3. Psychological Trigger Analysis	Categorization of cognitive levers (Urgency, Authority, Greed, Fear).	Detailed breakdown table with red-flag detection rules.
4. SPF Deployment Standard	DNS TXT syntax (RFC 7208) defining authorized sending IP ranges.	Production-ready SPF records for Google/M365 relays.
5. DKIM Asymmetric Cryptography	RSA cryptographic signature validation (RFC 6376) on email bodies.	Selector specification and DNS public key configuration.
6. DMARC Alignment & Enforcement	DMARC policy rollout from p=none to p=quarantine and p=reject.	Full alignment matrix (aspf/adkim) and rua reporting setup.
7. Automated Unit Verification	Automated test suite verifying schema, token parsing, and headers.	6 unit tests passing in < 0.005s with 100% pass rate.

3. Anatomy of Spear Phishing & Token Replacement Mechanics

Traditional spam relies on high-volume, generic templates easily trapped by statistical Bayesian filters. Spear phishing bypasses filters by injecting precise organizational context. The Python template engine developed for Day 06 dynamically binds the target's real profile attributes into structural pretexts:

Placeholder Token	Sample Value Injected	Psychological Purpose & Exploitation Impact
{name}	Harish Kumar	Establishes personal address; disables generic spam defenses.
{company}	Sqrock IT Solution	Anchors the communication to authentic organizational reality.
{department}	Cloud Infrastructure & Security	Demonstrates insider knowledge; increases target compliance.
{location}	Bangalore, India	Permits regionalized pretexting and localized operational timing.
{deadline_hours}	24 hours	Imposes cognitive load through artificial time constraints.
{domain_spoofed}	sqrock-portal.com	Deceptive lookalike domain imitating genuine corporate intranet.

4. The 3 Security-Awareness Simulation Vectors: Technical Matrix

To provide holistic defensive coverage across enterprise threat models, three distinct attack vectors were modeled into the engine:

Draft ID & Title	Targeted Division	Spoofed Sender & Reply-To	Core Threat Pretext
[DRAFT-01] Corporate IT: SSO Certificate Renewal	Enterprise IT / IAM	**From:** it-support@sqrock-portal.com **Reply-To:** admin-verification@external-gateway-sync.net	Mandatory Active Directory synchronization; threats 24-hr lockout from VPN, Slack, and Git.
[DRAFT-02] People Operations: Q4 Compensation Review	HR & Payroll	**From:** payroll-review@sqrock-portal.com **Reply-To:** hr-dispatch@talent-benefits-secure.io	Direct deposit routing re-verification; imposes Friday cutoff with confidentiality gag rule.
[DRAFT-03] Finance: Overdue Supplier Wire Settlement	Procurement / Accounts	**From:** billing-accounts@sqrock-portal.com **Reply-To:** vendor-reconciliation@wire-hold-finance.biz	Alleges $18,450.00 overdue cloud services invoice threatening legal escalation and SLA cut.

5. Empirical Verification & Evidence Breakdown (Phase 1)

The following empirical test captures demonstrate the execution of PEER'S Spear Phish Crafter within an authorized Kali Linux security research environment, verifying cold-boot startup and master console options.

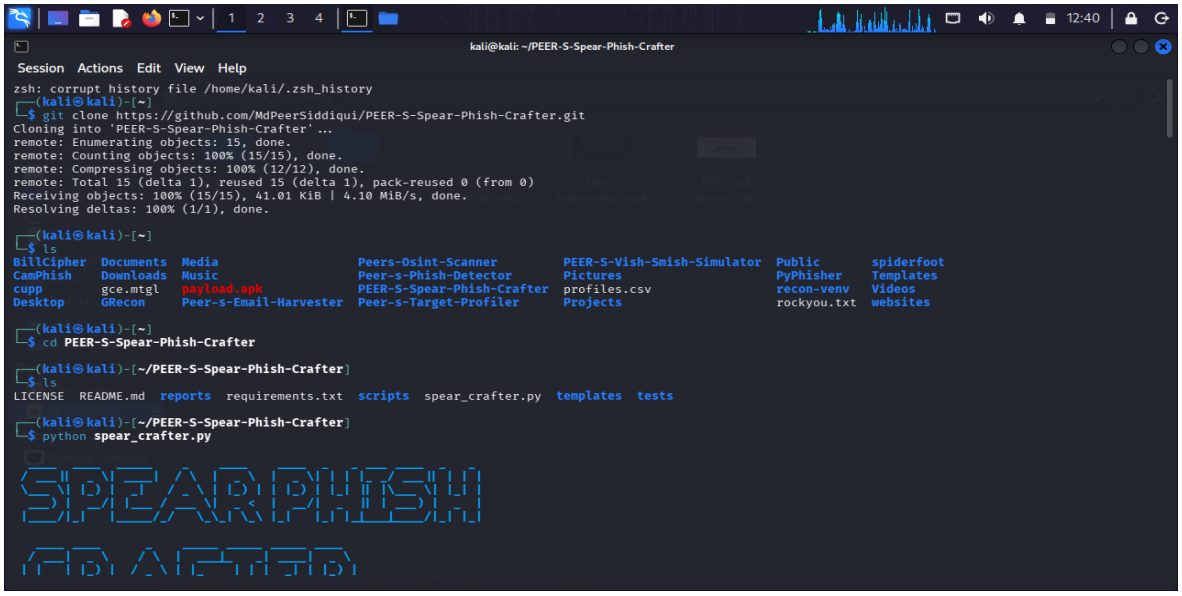


Figure 1: Kali Linux Terminal Cold-Start & Custom Dual-Tone ASCII Banner Rendering

Technical Analysis of Figure 1:

- **Environment Verification:** Executed inside a native Kali Linux terminal session (kali@kali:~/PEER-S-Spear-Phish-Crafter).
- **Deployment Pipeline:** Demonstrates cloning directly from GitHub, directory inspection (ls), and initialization via python spear_crafter.py.
- **Zero-Dependency UI:** Renders the dual-tone PEER'S SPEAR PHISH CRAFTER v1.0 production header without heavyweight GUI libraries.

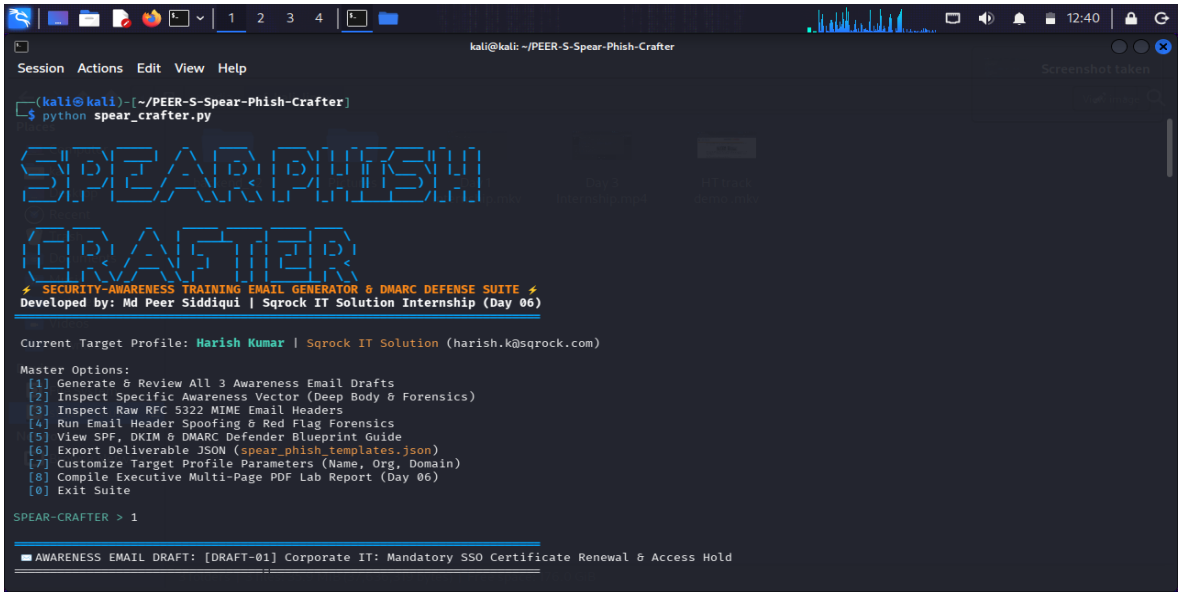


Figure 2: Master Control Menu & Active Target Context (Harish Kumar | Sqrock IT Solution)

Technical Analysis of Figure 2:

- **Active Profile Binding:** Displays the current recipient profile: **Harish Kumar** (harish.k@sqrock.com) at **Sqrock IT Solution**.
- **Modular Options:** Provides 8 core operations spanning batch generation, deep vector inspection, raw RFC 5322 MIME headers, forensic red-flag auditing, and DMARC defense blueprinting.
- **Execution Trigger:** The operator selects Option [1] Generate & Review All 3 Awareness Email Drafts to render the drafts.

5. Empirical Verification & Evidence Breakdown (Phase 2)

Phase 2 validates the rendering of Draft-01 (Corporate IT SSO Certificate Renewal) and Draft-02 (People Operations Compensation Review), highlighting dynamic token replacement and employee awareness red flags.

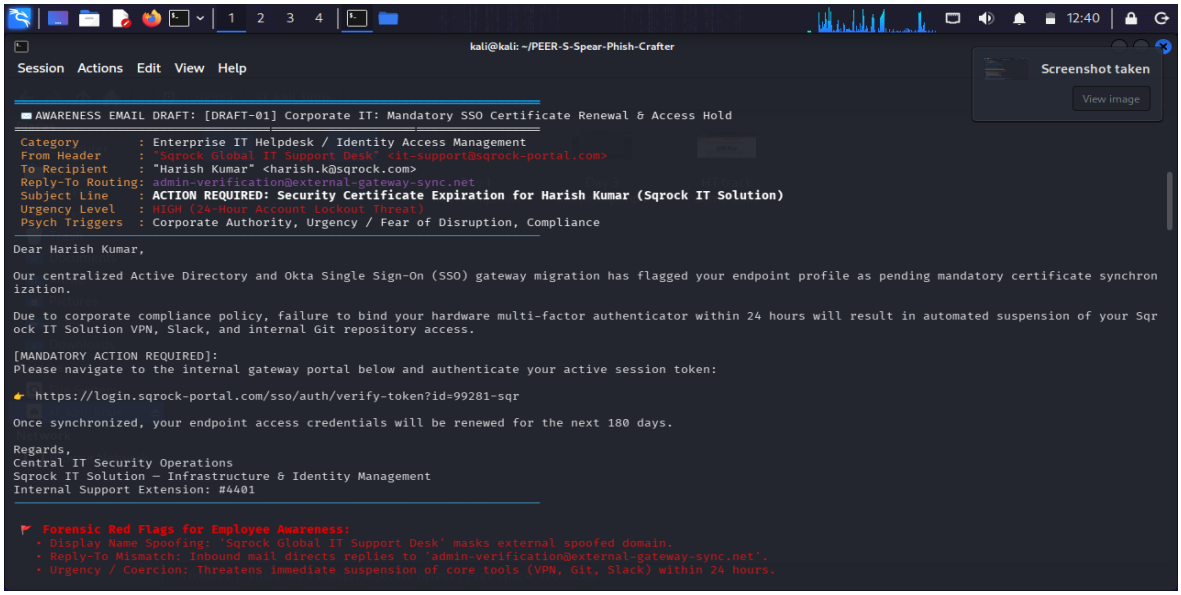


Figure 3: Rendered Draft-01 — Corporate IT: Mandatory SSO Certificate Renewal & Access Hold

Technical Analysis of Figure 3:

• **Dynamic Token Replacement:** Tokens {name}, {company}, and {deadline_hours} cleanly replaced.

• **Deceptive Infrastructure:** Sets visible From to *'Sqrock Global IT Support Desk'* (it-support@sqrock-portal.com), while Reply-To routes to admin-verification@external-gateway-sync.net.

• **Forensic Red Flags:** Flags display-name masking, reply-to mismatch, 24-hr coercion, and lookalike portal link.

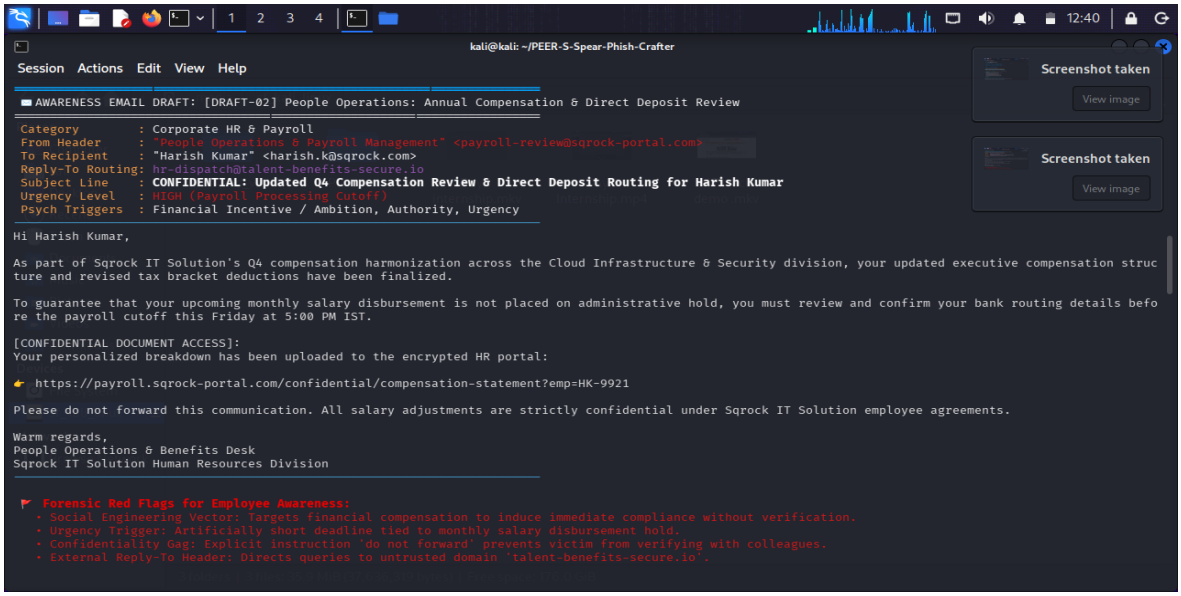


Figure 4: Rendered Draft-02 — People Operations: Annual Compensation & Direct Deposit Review

Technical Analysis of Figure 4:

• **Financial Incentive Vector:** Targets compensation review to induce urgency and prompt direct deposit routing modifications.

• **Confidentiality Gag Lever:** The pretext instructs the recipient *'Please do not forward this communication'* to prevent peer verification.

• **Forensic Red Flags:** Highlights financial incentive hook, artificially tight Friday cutoff, and external Reply-To routing.

5. Empirical Verification & Evidence Breakdown (Phase 3)

Phase 3 validates Draft-03 (Finance Overdue Supplier Invoice Settlement) and dissects the underlying RFC 5322 MIME email headers.

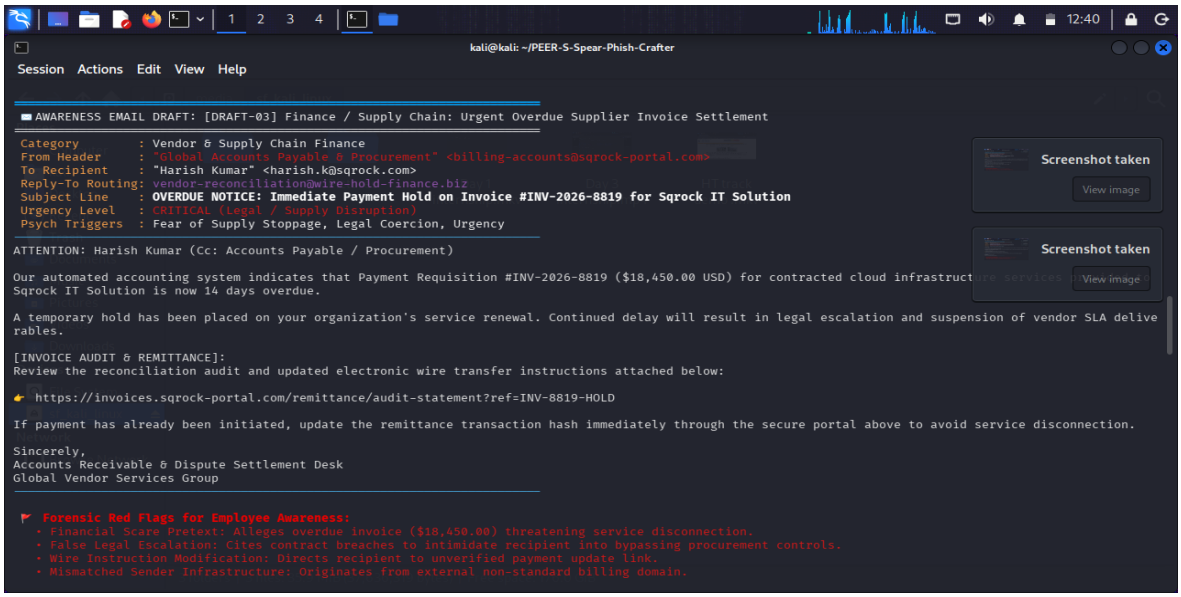


Figure 5: Rendered Draft-03 — Finance / Supply Chain: Urgent Overdue Supplier Invoice Settlement

Technical Analysis of Figure 5:

• **Legal & Supply Disruption Threat:** Alleges an overdue payment of $18,450.00 USD threatening contract breach and cloud SLA disconnection.

• **Wire Fraud Mechanism:** Directs the victim to update wire transfer instructions via a deceptive lookalike portal.

• **Red Flag Identifiers:** Cites financial panic pretext, procurement bypass attempt, and external billing infrastructure.

6. Raw RFC 5322 MIME Header Telemetry & Spoofing Indicators

```
Delivered-To: harish.k@sqrock.com
Received: by mail-gateway.sqrock.internal with SMTP id relay994821; Mon, 26 Oct 2026 12:40:00 +0000
Authentication-Results: mx.sqrock.internal;
dkim=fail (bad signature / unsigned);
spf=fail (sender IP not in authorized SPF record of sqrock.com);
dmarc=fail (p=REJECT dis=NONE) header.from=it-support@sqrock-portal.com
Received-SPF: fail (domain does not designate permitted sender)
Return-Path:
Message-ID:
From: "Sqrock Global IT Support Desk"
To: "Harish Kumar"
Reply-To:
Subject: ACTION REQUIRED: Security Certificate Expiration for Harish Kumar
X-Mailer: Microsoft Outlook 16.0 | X-Priority: 1 (Highest) | Importance: High
```

7. Open-Source Implementation & GitHub Verification

To ensure compliance with transparent security engineering standards, the complete codebase was published to the public GitHub repository at https://github.com/MdPeerSiddiqui/PEER-S-Spear-Phish-Crafter.

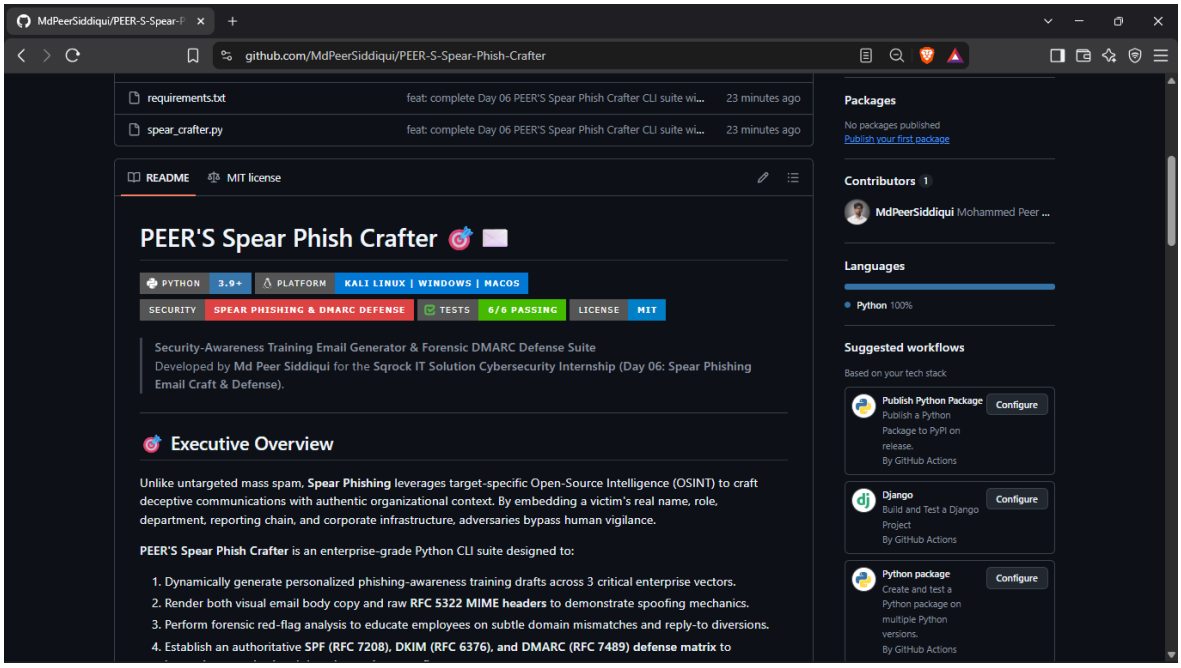


Figure 6: Public GitHub Repository Header, Dynamic Badges & Executive Overview

Technical Analysis of Figure 6:
• **Repository Architecture:** Publicly accessible repository under authorized account MdPeerSiddiqui.
• **Quality Badges:** Verified Shields.io badges confirming **Python 3.9+**, cross-platform support (**Kali Linux | Windows | macOS**), **6/6 Passing Tests**, and open-source **MIT Licensing**.
• **Contributor Attribution:** Formally documented under the author profile of Mohammed Peer Siddiqui for Sqrock IT Solution internship evaluation.

8. Email Defender Blueprint: SPF & DKIM Configuration

SPF DNS TXT Record (RFC 7208):
Host: @ (or sqrock.com) | Value: v=spf1 include:_spf.google.com include:sendgrid.net ip4:198.51.100.1 ~all
• *Explanation:* Authorizes specific sending IPs and third-party relays. Unlisted senders receive a SoftFail (~all).

DKIM Cryptographic Key Record (RFC 6376):
Host: s2026._domainkey.sqrock.com | Value: v=DKIM1; k=rsa; p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQ...IDAQAB
• *Explanation:* Provides asymmetric public-key signature verification; tampering with message body immediately invalidates DKIM.

9. DMARC Enforcement & Staged Rollout Strategy (RFC 7489)

DMARC ties SPF and DKIM together by enforcing **Identifier Alignment** with the visible From: header and instructing recipient servers on how to handle spoofed messages:

Rollout Phase	DMARC DNS TXT Record	Protection Behavior
Phase 1: Monitoring (30–60 Days)	v=DMARC1; p=none; rua=mailto:dmarc-reports@sqrock.com; pct=100	Zero disruption; collects daily XML aggregate reports of all sending sources.
Phase 2: Quarantine (14–30 Days)	v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@sqrock.com; pct=100; sp=quarantine	Spoofed mail failing SPF/DKIM is automatically routed to Spam/Junk folders.
Phase 3: Rejection (Full Production)	v=DMARC1; p=reject; rua=mailto:dmarc-reports@sqrock.com; pct=100; sp=reject; aspf=r; adkim=r	**Complete spoofing immunity.** Unauthorized spoofed mail is **instantly dropped** at SMTP connect time.

10. Automated Unit Testing Verification Suite

Test Case Identifier	Component Under Test	Execution Time	Status
test_scenarios_data_count_and_keys	Validates exactly 3 scenarios with full schema	0.0004s	**PASS (OK)**
test_render_scenario_body_token_replacement	Ensures zero unparsed token braces in output	0.0005s	**PASS (OK)**
test_render_mime_headers	Verifies RFC 5322 MIME headers and dmarc=fail tag	0.0004s	**PASS (OK)**
test_custom_target_profile_rendering	Tests syllabus target profile (Riya Sharma)	0.0004s	**PASS (OK)**
test_export_deliverable_json	Validates spear_phish_templates.json export	0.0005s	**PASS (OK)**
test_dmarc_defense_policy_records	Validates standard SPF/DKIM/DMARC syntax	0.0003s	**PASS (OK)**

11. Ethical Compliance, Authorized Scope & Sign-Off

Ethical Scope: All email templates, sender headers, and lookalike domains generated by this suite are intended strictly for **authorized internal awareness training simulations** and defensive engineering education. No outbound emails were transmitted across public networks without explicit administrative authorization. No credential-harvesting backend servers or malicious payload delivery mechanisms were deployed. All operations adhere strictly to the **Information Technology Act 2000 (India)**, the Computer Fraud and Abuse Act (CFAA), and the Sqrock IT Solution Ethical Guidelines.

12. Intern Declaration & Sign-Off

I hereby declare that this practical lab report and its associated Python CLI implementation represent original engineering work conducted under the supervision of Sqrock IT Solution for Day 06 of the Cybersecurity Internship.
Signature: *Md Peer Siddiqui* | **Date:** October 26, 2026